

82 - Role based authorization

- аутентификация – кой е потребителят;
- авторизация – какво може
 - [Authorize] – проста, за всички изисква просто да са вписани
 - [Authorize(Roles = "Admin")] – за конкретен потребител

ASP.NET Core Role Based Authorization

Simple Authorization - Part 71 of ASP.NET Core Tutorial

```
[Authorize]
public class SomeController : Controller
{
}
```

Only members of the Administrator role have access

```
[Authorize(Roles = "Administrator")]
public class AdministrationController : Controller
{
}
```

The screenshot shows the `AdministrationController.cs` file in Visual Studio. The `[Authorize(Roles = "Admin")]` attribute is applied to the controller. To the right, a list of users and their roles is displayed:

User	Role
julia@abv.bg	User
aurora@abv.bg	User
sara@abv.bg	Admin
bob@abv.bg	Admin
david@abv.bg	-
tim@abv.bg	-

При това положение, въведен в контролера, изисква вписване преди да даде достъп до `administration/listroles` ->

При login като обикновен user:

localhost:24077/Account/AccessDenied?ReturnUrl=%2Fadministration%2Flistroles

При logout прехвърля към формата за вписване:

/Account/Login?ReturnUrl=%2Fadministration%2Flistroles

При мен, обаче, след вписване пренасочва към 404. Без [Authorize] няма проблеми. Четох, че след .Net 3.0 изисква добавяне на `app.UseAuthorization();` след `app.UseAuthentication();`, но при мен изкарва Warning, който пак стои със зелено подчертаване.

```
app.UseAuthorization();
UseMvc(rb => //app.usemvcwithdefaultrouting
Use discard '_'
Suppress or Configure issues
IDE0058 Expression value is never us
Lines 68 to 70
app.UseAuthentication();
app.UseAuthorization();
= app.UseAuthorization();
```

Опитах да добавя и

```
services.AddAuthorization(options =>
options.AddPolicy("Role",
policy => policy.RequireClaim(ClaimTypes.Role, "Admin")));
```

Пак не става, независимо, че давам Logout всеки път и вписвам админски потребител, при самото пренасочване връща 404.

По същият начин не работи при [Authorize(Roles = "User")]

Само [Authorize] работи без проблеми.

```
services.AddAuthorization(options =>
options.AddPolicy("Role",
policy => policy.RequireRole("Admin")));
```

В същото време, имам:

```
Startup.cs
EmployeeManagement.Startup

services.AddMvc(options =>
{
options.EnableEndpointRouting = false;
var policy = new AuthorizationPolicyBuilder()
.RequireAuthenticatedUser()
.Build();
options.Filters.Add(new AuthorizeFilter(policy));
}).AddXmlSerializerFormatters();
```

```
app.UseStaticFiles(); //Short-circle ordering
app.UseAuthentication();
app.UseAuthorization();
app.UseMvc()
{
rb.MapRoute
});
```

(extension) IApplicationBuilder IApplicationBuilder.UseAuthorization()
Adds the AuthorizationMiddleware to the specified IApplicationBuilder, which enables authorization capabilities.
When authorizing a resource that is routed using endpoint routing, this call must appear between the calls to app.UseRouting() and app.UseEndpoints(...) for the middleware to function correctly.

```

app.UseStaticFiles();
app.UseAuthentication();

app.UseMvc(rb => //app.usemvc
{
    rb.MapRoute("default", "{co
});

app.UseRouting();
app.UseAuthorization();
app.UseEndpoints(endpoints =>

```

Edit Role

Id: 7a53c902-d9f9-4026-b521-26b8485f1611

RoleName: Admin

Update
Cancel

Users in this role

sara@abv.bg

bob@abv.bg

Add or remove users

С това преместване, зеленото подчертаване изчезна.

`UseAuthorization();` трябва да бъде след `UseAuthentication();` и между `app.UseRouting();` и `app.UseEndpoints();`

Разбрах откъде е грешката: един интервал, който не се вижда след Admin_ когато съм задавала името. Открих го с Admin1, при User също нямаше проблеми. Това показва уязвимост. Трябва да има абсолютно съвпадение! По-резонно щеше да бъде, ако бях объркала А с кирилица.

ASP.NET Core Role Based Authorization

Members of either Administrator or User role have access

```

[Authorize(Roles = "Administrator,User")]
public class AdministrationController : Controller
{
}

```

To access users have to be members of both Administrator role and User role

```

[Authorize(Roles = "Administrator")]
[Authorize(Roles = "User")]
public class AdministrationController : Controller
{
}

```

Добавяме още един потребител User, така че или Admin и User имат право на достъп. За да влязат в сила промените, винаги трябва да дадем Logout-> Login.

Правим тестови проверки.

`[Authorize(Roles = "Admin,User")]`
 не е еквивалентно като действие с
`[Authorize(Roles = "Admin,User")]`
`[Authorize(Roles = "User")]`

във втория случай, трябва потребителят да бъде едновременно Admin + User

ASP.NET Core Role Based Authorization

pragim@pragimtech.com	Admin
abc@gmail.com	User
test@pragimtech.com	Admin, User

ASP.NET Core Role Based Authorization

```
[Authorize(Roles = "Administrator, User")]
public class AdministrationController : Controller
{
    public ActionResult ABC()
    {
    }

    [Authorize(Roles = "Administrator")]
    public ActionResult XYZ()
    {
    }

    [AllowAnonymous]
    public ActionResult Anyone()
    {
    }
}
```

Members of Administrator or User role have access

Only members of Administrator role have access

Anyone including anonymous users have access

В моя случай оставям aurora@abv.bg да бъде Admin+User.